

Cvičení 9 — Generátory pseudonáhodných čísel

1. Blum Blum Shub generátor

1.1 Popis algoritmu

Blum Blum Shub (BBS) je kryptograficky bezpečný PRNG (Stallings, str. 260). Postup:

- Zvolíme dvě velká prvočísla **p** a **q** splňující podmínku **p ≡ q ≡ 3 (mod 4)**.
- Vypočítáme **n = p · q** (Blumovo číslo, ~1024 bitů).
- Zvolíme seed **x0** nesoudělný s n.
- Generujeme bity: `x_(i+1) = x_i^2 mod n`, `bit_i = x_(i+1) mod 2`.

1.2 Parametry generování

Parametr	Hodnota
Délka prvočísel p, q	512 bitů
Test prvočíselnosti	Miller-Rabin (25 kol)
Podmínka	p ≡ 3 (mod 4) ✓, q ≡ 3 (mod 4) ✓
n = p · q	~1024 bitů
Vygenerováno bitů	1024 (uloženo do <code>bbs_output.bin</code>)

Výstup generování:

```
Generuji dvě 512-bitová Blumova prvočísla (p ≡ q ≡ 3 mod 4) ...  
p ≡ 3 (mod 4) [OK]  
q ≡ 3 (mod 4) [OK]  
n = p · q má 1024 bitů
```

1.3 Statistické testy

[a] Test uniformního rozdělení

Ověřuje poměr jedniček a nul. Ideální poměr je 50 %. Sekvence je vyvážená, pokud odchylka nepřekročí 5 %.

	BBS	secrets
Jedničky	523 (51,07 %)	507 (49,51 %)
Nuly	501 (48,93 %)	517 (50,49 %)
Vyváženo (± 5 %)	ANO	ANO

[b] Test opakovatelnosti

BBS je deterministický — stejné vstupy (n, xo) vždy vrátí identický výstup.

	BBS
Deterministický výstup	ANO

`secrets` je záměrně nedeterministický (čerpá z entropie OS), opakovatelnost se netestuje.

[c] Test běžných sekvencí — runs & gaps

Testuje délky nepřerušovaných sekvencí jedniček a nul. U náhodné posloupnosti délky sledují geometrické rozdělení — nejčtenější jsou krátké běhy (délka 1), výskyt klesá s délkou.

Parametr	BBS	secrets
Celkem běhů	513	536
Průměrná délka běhu	2,00	1,91
Nejdelsí běh	21	9
Běhů jedniček	257	268
Běhů nul	256	268

Distribuce délek běhů jedniček:

Délka	BBS	secrets
1	131×	139×
2	62×	67×
3	32×	38×
4	20×	12×
5	4×	4×
6	4×	6×
7	1×	1×
8+	2×	1×

Distribuce délek běhů nul:

Délka	BBS	secrets
1	135×	151×
2	57×	55×
3	32×	26×
4	15×	15×
5	11×	12×
6	2×	6×
7	3×	2×
8+	1×	1×

Obě distribuce mají exponenciálně klesající tvar — odpovídá náhodné posloupnosti.

1.4 Porovnání BBS vs. secrets [d, e]

Knihovna `secrets` využívá `os.urandom()` / `/dev/urandom` (čerpá z entropie OS).

Vlastnost	BBS	secrets (CSPRNG)
Jedničky	523 (51,07 %)	507 (49,51 %)
Nuly	501 (48,93 %)	517 (50,49 %)
Uniformita (±5 %)	ANO	ANO
Celkem běhů	513	536
Průměrná délka běhu	2,00	1,91
Nejdelší běh	21	9
Kryptograficky bezpečný	ANO (při velkých p, q)	ANO
Výpočetní náročnost	Vysoká (modulární exp.)	Nízká
Zdroj entropie	Matematická konstrukce	os.urandom()
Opakovatelnost	ANO (deterministický)	NE

Závěr: Statistické výsledky jsou srovnatelné — obě sekvence jsou vyvážené a mají geometrickou distribuci délky běhů. Zásadní praktický rozdíl je výpočetní náročnost: BBS provádí kvadratické mocnění modulo ~1024-bitové číslo pro každý bit, zatímco `secrets` je výrazně rychlejší. Pro produkční použití je `secrets` preferovanou volbou.

2. (Ne)bezpečnost random.random()

2.1 Popis zranitelnosti

`random.random()` v Pythonu je implementací **Mersenne Twisteru (MT19937)** — rychlý, statisticky kvalitní generátor, ale **není kryptograficky bezpečný** ze dvou důvodů:

1. **Předvídatelnost stavu** — z 624 po sobě jdoucích 32-bitových výstupů lze plně rekonstruovat vnitřní stav MT a předvídat všechny budoucí (i minulé) hodnoty.
2. **Slabý seed z času** — aplikace seedující generátor pomocí `int(time.time())` je zranitelná: útočník s přibližnou znalostí doby spuštění prohledá okno řádu sekund a seed triviálně najde.

2.2 Scénář útoku

Cílová aplikace generuje **6 náhodných čísel z intervalu {1, 49}** seedovaných aktuálním časem. Útočník zachytí sekvenci a prohledá posledních 120 sekund.

2.3 Výsledky útoku

Simulace cílové aplikace

Zachycená posloupnost : [4, 28, 35, 39, 34, 40]

Skutečný seed : 1777282114 (útočník toto NEZNÁ)

Útok: prohledávání časového okna (posledních 120 s)

Hledám v rozsahu seedů: 1777281994 - 1777282114

Počet kandidátů : 121

Výsledek

Nalezený seed : 1777282114

Skutečný seed : 1777282114

Shoda seedů : ANO [OK]

Doba útoku : 2.5 ms

Přegenerovaná posloupnost : [4, 28, 35, 39, 34, 40]

Zachycená posloupnost : [4, 28, 35, 39, 34, 40]

Shoda sekvencí : ANO [OK]

Předpověď dalších čísel v posloupnosti

Dalších 6 čísel (pozice 7-12) : [33, 28, 27, 26, 31, 14]

Parametr	Hodnota
Zachycená posloupnost	[4, 28, 35, 39, 34, 40]
Prohledávání kandidátů	121 seedů (120 sekund)
Seed nalezen	ANO
Doba útoku	2,5 ms
Předpovězená pokračování	[33, 28, 27, 26, 31, 14]

2.4 Závěr

Útok uspěl za **2,5 ms** prohledáním pouhých 121 kandidátů. To demonstruje, proč `random.random()` seedovaný časem není bezpečný pro kryptografické účely.

Bezpečná alternativa:

```
# Místo:
random.seed(int(time.time()))
numbers = [random.randint(1, 49) for _ in range(6)]

# Použít:
numbers = [secrets.randbelow(49) + 1 for _ in range(6)]
```

`secrets` využívá `os.urandom()` / `/dev/urandom` — čerpá z entropie systému, nelze předvídat ani reprodukovat.

3. Celkové shrnutí

Generátor	Typ	Kryptogr. bezpečný	Poznámka
BBS	CSPRNG	ANO	Pomalý; bezpečný při velkých p, q
secrets	CSPRNG	ANO	Rychlý; produkční standard v Pythonu
random.random()	PRNG	NE	Mersenne Twister; předvídatelný stav i seed